This project demonstrates how to secure an AWS environment by implementing **Identity and Access Management (IAM) security controls**, enforcing **least privilege access**, and building **real-time monitoring to detect privileged account activity**.

The goal was to simulate how a **security operations team would harden cloud identity infrastructure and monitor for potential privilege abuse**.

Threat Scenario

A malicious actor gains access to AWS credentials and attempts to log in using the **root account**.

Root account access is extremely dangerous because it provides **unrestricted administrative control** over the AWS environment.

The security objective is to:

1. Prevent root account misuse
2. Enforce identity verification
3. Detect privileged login attempts in real time

Security Controls Implemented

Identity Hardening

- Root account protected with **MFA**
- Strong **password policy enforcement**
- Removal of root account for daily tasks

aws | Search [Option+S] | Global | Ryan_Brown

IAM > Account Settings > Edit password policy

Edit password policy Info

Password policy

- IAM default
  Apply default password requirements.
- Custom
  Apply customized password requirements.

Password minimum length.
Enforce a minimum length of characters.

12 characters

Needs to be between 6 and 128.

Password strength

- [x] Require at least one uppercase letter from the Latin alphabet (A-Z)
- [x] Require at least one lowercase letter from the Latin alphabet (a-z)
- [x] Require at least one number
- [x] Require at least one non-alphanumeric character (! @ # $ % ^ & * ( ) _ + - = [ ] {} | ')

Other requirements

- [x] Turn on password expiration
  Expire password in 90 day(s)
  Needs to be between 1 and 1095 days.
- [x] Password expiration requires administrator reset
- [x] Allow users to change their own password
- [x] Prevent password reuse
  Remember 12 password(s)
  Needs to be between 1 and 24.

✓ **Password requirements for IAM users are updated.** ×

Account settings Info

Password policy Info

Edit

Configure the password requirements for the IAM users.

This AWS account uses the following custom password policy:

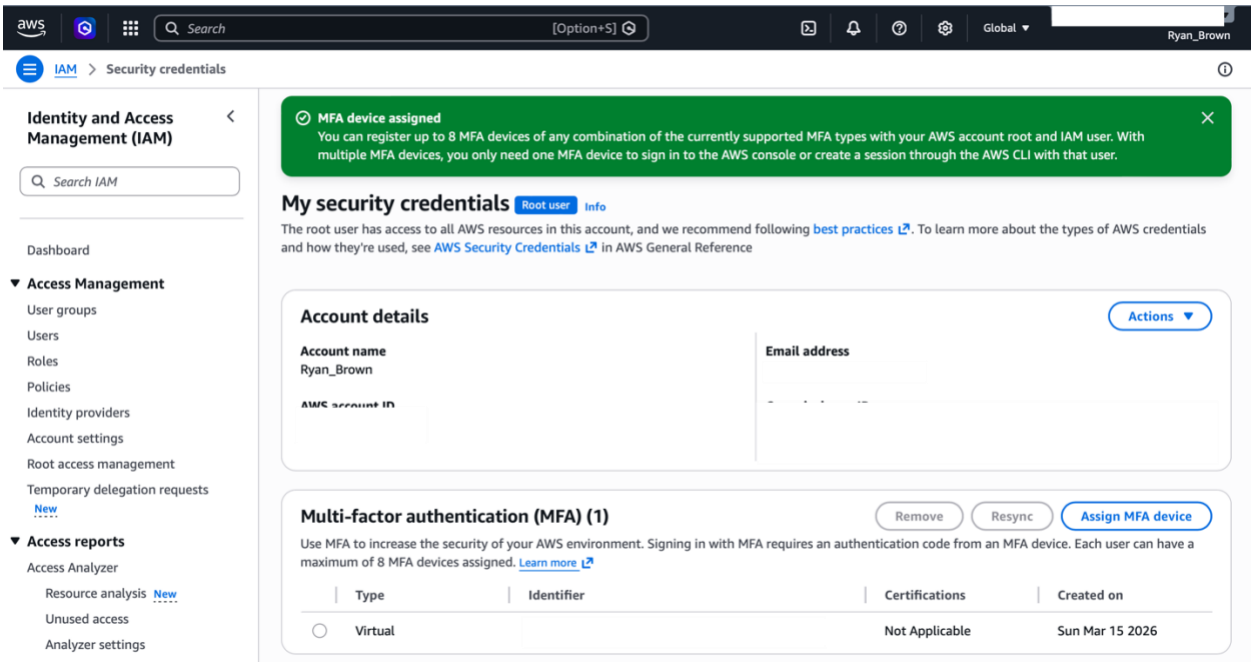
Password minimum length
12 characters

Password strength

- Require at least one uppercase letter from the Latin alphabet (A-Z)
- Require at least one lowercase letter from the Latin alphabet (a-z)
- Require at least one number
- Require at least one non-alphanumeric character

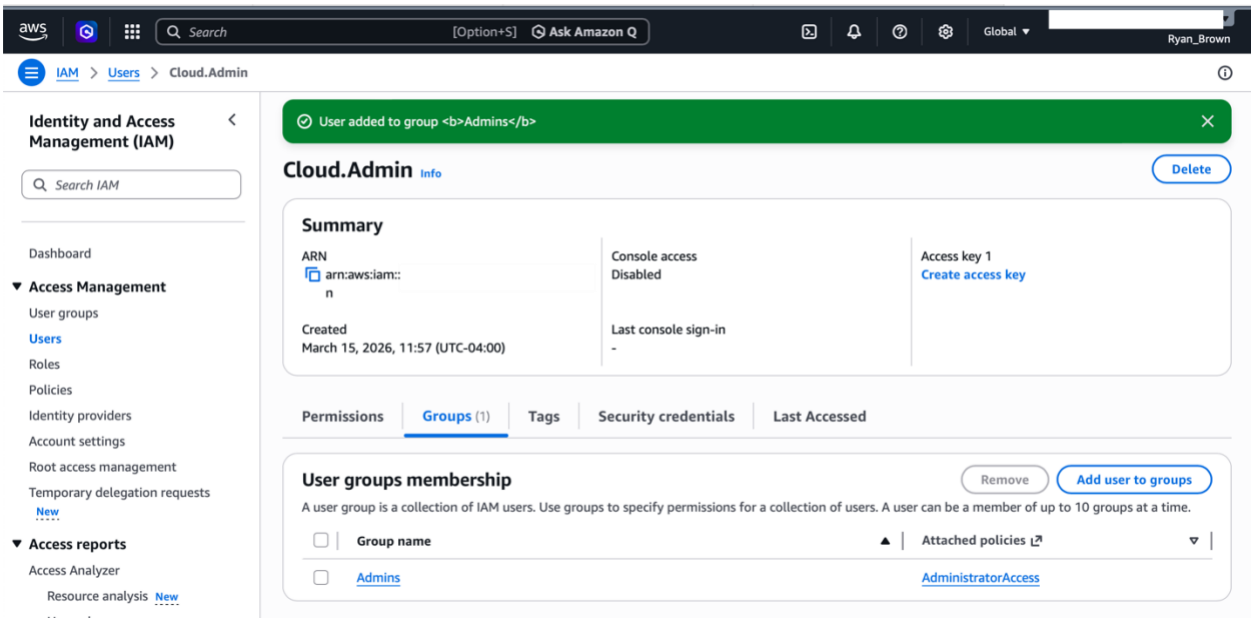
Other requirements

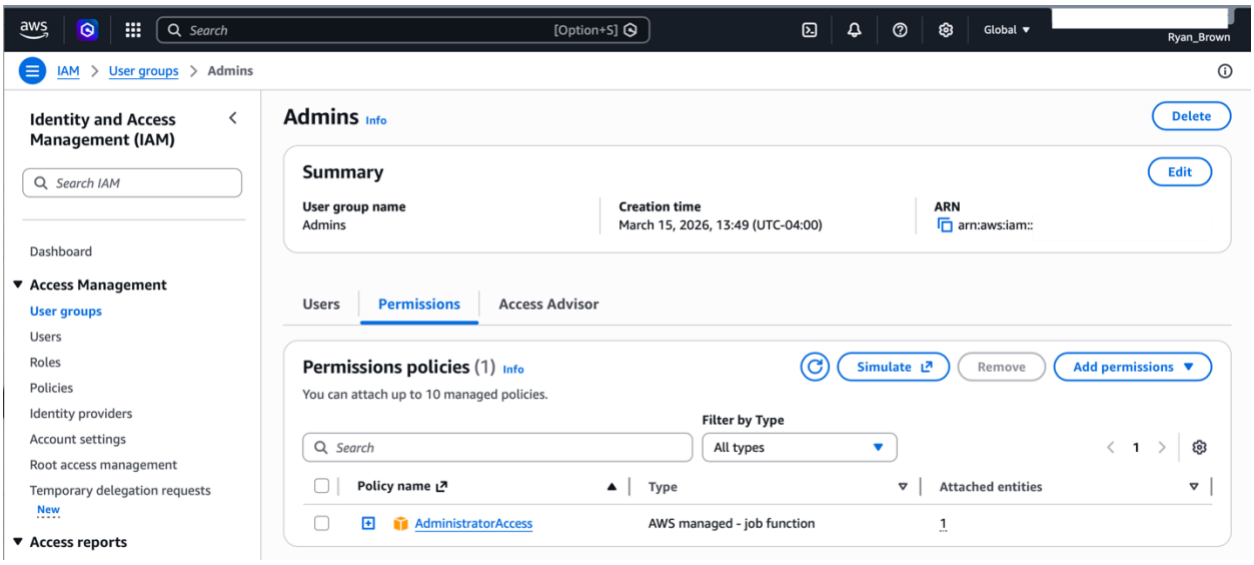
- Password expires in 90 day(s)
- Password expiration requires administrator reset
- Allow users to change their own password
- Prevent password reuse from the past 12 changes



Identity Governance

- **Admins IAM Group** created
- Permissions assigned at the **group level**
- Prevents **permission creep**



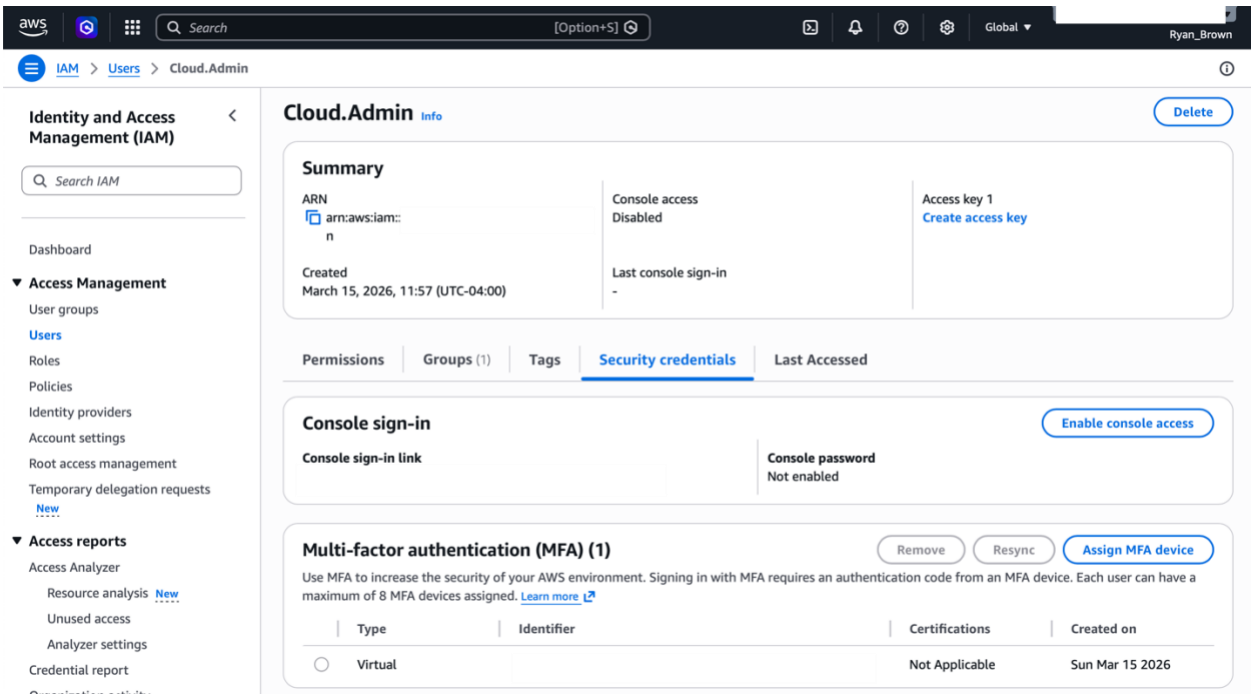


Multi-Factor Authentication

All administrative users were required to enable **virtual MFA devices**.

This significantly reduces the risk of:

- Credential theft
- Unauthorized console access
- Privilege escalation



Threat Detection Implementation
CloudTrail Logging

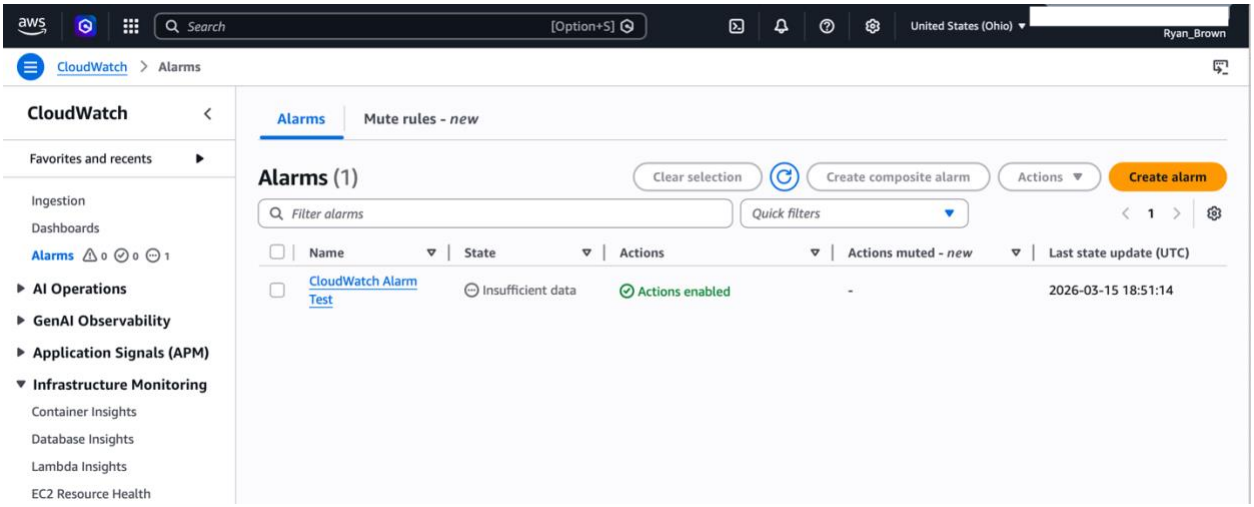
CloudTrail was enabled to capture **all account authentication activity and API calls**. This ensures a **forensic audit trail** of identity-related activity.

Detection Logic

A **CloudWatch Log Metric Filter** was created to detect root account login events.

Detection Pattern:
{ ($.eventName = "ConsoleLogin") && ($.userIdentity.type = "Root") }

This pattern isolates console logins where the **user identity type is Root**.



Automated Alerting

A **CloudWatch Alarm** was configured to trigger an **SNS notification** when the detection rule fires.

Security team members receive an **email alert immediately when a root login occurs**.

Simple Notification Service

Subscription confirmed!

You have successfully subscribed.

Your subscription's id is:
`arn:aws:sns:us-east-`
`:Default_CloudWatch_Alarms_Topic:`

If it was not your intention to subscribe, click here to unsubscribe.

Security Operations Analysis

From a **SOC analyst perspective**, this monitoring pipeline enables immediate detection of privileged identity misuse.

If a root login occurs, the security team can quickly:

1. Investigate the login source IP
2. Verify whether the login is authorized
3. Initiate incident response if necessary

This significantly reduces **time-to-detection (TTD)** for high-risk authentication events.

Key Security Outcomes

- Implemented **least privilege identity model**
- Secured root account with **MFA**
- Enforced **strong password policies**
- Established **group-based access control**
- Built **real-time monitoring of privileged activity**
- Integrated **CloudTrail, CloudWatch, and SNS**